



A hybrid scoring system for prioritization of software vulnerabilities

Abhishek Sharma*, Sangeeta Sabharwal, Sushama Nagpal

Department of Computer Science and Engineering, Netaji Subhash University of Technology, Delhi

ARTICLE INFO

Article history:

Received 11 April 2022

Revised 1 November 2022

Accepted 9 April 2023

Available online 10 April 2023

Keywords:

Vulnerability

Prioritization

Scoring

CVSS

Impact

Exploitability

ABSTRACT

While security experts, firms, security providers, threat analysts all around the globe are working hard to provide ironclad security for information system softwares, vulnerabilities in softwares are still being detected on a daily basis. Although it is very important to neutralize all these vulnerabilities as quickly as possible, prioritization of vulnerabilities to determine the order for resolving these vulnerabilities is an equally important step for optimization of the remediation process. Among different available techniques for prioritization of vulnerabilities, scoring the vulnerabilities is the most common practice. In this paper, we have proposed a novel hybrid technique, VIEWSS: Variable Impact-Exploitability Weightage Scoring System, which scores vulnerabilities by varying the Impact-Exploitability score ratio towards calculation of base scores. We have also discussed three popular quantitative vulnerability scoring techniques; CVSS (Common Vulnerability Scoring System), VRSS (Vulnerability Rating and Scoring System) and WIVSS (Weighted Impact Vulnerability Scoring System) by explaining the underlying metrics, scoring systems, formulas and some limitations of these techniques. The proposed technique, VIEWSS is also compared with the discussed techniques by generating scores for around 83,500 vulnerabilities reported on NVD (National Vulnerability Database) in the last five years. It is observed that our proposed technique generates the greatest number of distinct scores and also the score distribution of our technique performs well on different parameters including skewness and kurtosis. Further when these techniques were applied on a dataset containing around 12,200 'high-risk' vulnerabilities extracted by cross-referencing NVD and Exploit-DB, our proposed technique outperformed all the discussed techniques in terms of identifying the threat accurately.

© 2023 Elsevier Ltd. All rights reserved.

1. Introduction

There are several ways to define a vulnerability (Complete CVSS v1 Guide, 2022; Shirey, 2007), but the definition most suited to the essence of this paper can be stated as "A vulnerability is a defect or weakness in a software which can be exploited by an attacker to jeopardize the Confidentiality(C), Integrity(I) and Availability(A) of a system". This definition contains the basis to calculate the severity of a vulnerability. We can measure the severity if we can quantify the chances of accessibility or exploitability of a vulnerability and impact of its successful exploitation on C, I, A of the system. Thousands of vulnerabilities are added to NVD (National Vulnerability Database: An open-source database for software vulnerabilities) each month. In September 2019, a report published by NIST claimed that NVD contained more than 1,20,000 vulnerabilities (API Vulnerabilities, 2022). From October 2019 to December 2021, 43,307 more vulnerabilities have been added to NVD. The graph in Fig. 1 shows no. of vulnerabilities added to NVD each

month from January 2020 to December 2021. The number of vulnerabilities added each month in NVD are retrieved using the web service offered by NVD (NVD - Data Feeds, 2022).

Growing number of vulnerabilities is surely a challenge and can be attributed to the fast-growing software industry. It is to be noted that not all vulnerabilities pose a threat to the systems. According to a report titled *Prioritization to Prediction: Volume 1* by Kenna Securities, 77% of the vulnerabilities in NVD are neither exploited nor any exploit code is published for these. 22% have been observed to have exploit codes and only 2% have been exploited successfully (Kenna Security, 2022). Most vulnerabilities remain unexploited throughout their lifecycle even with availability of exploit codes for them. It is not feasible to remediate all the vulnerabilities as it requires a substantial amount of time and resources on part of the concerned organizations. Hence to optimize the remediation, an assessment system for rating or scoring vulnerabilities is required.

Vulnerability severity assessment techniques can be divided into two types i.e., quantitative and qualitative. In quantitative techniques like (Complete CVSS v1 Guide, 2022; Liu and Zhang, 2011; Mell et al., 2007; Spanos et al., 2013; WANG, 2012), a

* Corresponding author.

E-mail address: abhishek.sharma.co18@nsut.ac.in (A. Sharma).

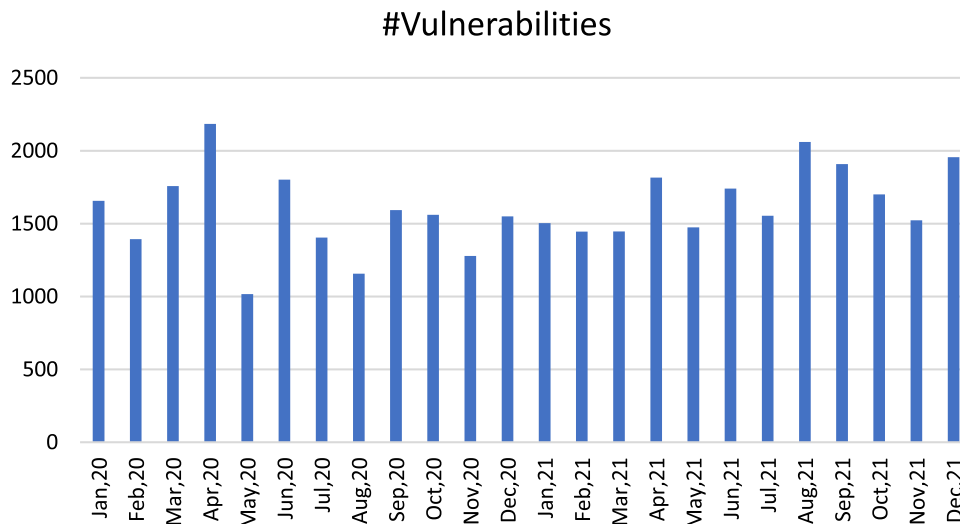


Fig. 1. Number of Vulnerabilities added to NVD each month from Jan, 2020 to Dec, 2021.

numerical score is assigned to the vulnerabilities whereas in qualitative techniques like (IBM X-Force Security Services | IBM, 2022; Symantec Security Center, 2022; About Secunia Research | Flexera, 2022; Security Update Guide - Microsoft, 2022; Severity Ratings - Red Hat Customer Portal, 2022; Mozilla Foundation Security Advisories - Mozilla, 2022; Severity Guidelines for Security Issues, 2022), vulnerabilities are classified into different severity classes (mostly 3, 4 or 5) based on their characteristics. We focus our attention on quantitative techniques in this work since a numerical score can also be used to classify the vulnerabilities by mapping it to respective severity class (Mell et al., 2007). CVSS is the most popular scoring system and is widely accepted as industry standard. It has emerged as a metric for risk assessment. For example, all IT products for the U.S. government needs to be assessed and managed using the NIST-certified SCAP protocol which says that organizations should use CVSS base score in prioritizing the remediation of security related software flaws. Another example is PCI DSS, the standard for security of credit card data, which says that criteria for ranking High risk vulnerabilities may include a CVSS score of 4.0 or above (Allodi and Massacci, 2014).

CVSS base score is generated by adding Impact score and Exploitability score. These scores are based on different values of metrics in the base metric group. There are many techniques proposed by researchers which are primarily based on CVSS base metric group. VRSS is one such hybrid technique, in which Impact score is calculated qualitatively and Exploitability score is quantitatively calculated (Liu and Zhang, 2011). WIVSS is another technique based on CVSS base metric group. In WIVSS, weights of the impact metric subgroup of CVSS base metric group are altered (Spanos et al., 2013). After studying CVSS, VRSS and WIVSS in detail we have identified some limitations which are as follows:

1. Weightage of Exploitability and Impact in final base scores is fixed in all the three techniques. The *Exploitability:Impact* weightage is fixed as 1:9 in VRSS, 3:7 in WIVSS and approximately as 4:6 in CVSS.
2. Due to fixed weightage, a vulnerability with *High* impact may be scored lower if its exploitability is *Low* or a vulnerability with *High* exploitability may be scored lower if its impact is *Low*.
3. The scores generated by VRSS are either too low or too high and highly biased towards Impact of a vulnerability.
4. Confidentiality (C), Integrity (I) and Availability (A) are considered as equally important in VRSS and CVSS, which is not prac-

tical. WIVSS approach of assigning different weights to C, I, A is more practical.

Keeping the above points in consideration, we have proposed a novel hybrid scoring system for vulnerabilities which addresses the above limitations. Our proposed system, VIEWSS (Variable Impact Exploitability Weightage Scoring System) gives variable weightage to impact and exploitability to better reflect the severity of each in the final base score. To evaluate the performance of our technique, we have applied our technique on a dataset containing high-risk vulnerabilities. We have set a threshold score of 6.0 for a vulnerability to be correctly identified as high risk, as scores above 6 lies in upper medium, high and critical severity class as per the industry standard CVSS. It is observed that the proposed technique was able to score the maximum number of vulnerabilities above the threshold of 6 in the high-risk dataset. Moreover, when applied on a dataset containing all vulnerabilities reported during 2017–2022, score distribution of our technique reflected better normality than that of others.

The organization of the paper is as follows. Section 2 gives an overview of the related work done in severity assessment of vulnerabilities. In Section 3, popular scoring systems, CVSS, VRSS and WIVSS are discussed. In Section 4, proposed scoring system, VIEWSS is explained in detail. In Section 5, we discuss two popular vulnerabilities and explain the steps used to calculate scores for these vulnerabilities using VIEWSS. In Section 6, we compare the proposed scoring system with the existing techniques and the performance of these techniques in terms of identifying high-risk vulnerabilities is analyzed. We finally conclude and give some insight for future work in Section 7.

2. Related work

Owing to the large number of vulnerabilities, several security organizations and researchers around the world have proposed different ways to prioritize vulnerabilities. Most of these are open source and their methodologies and formulae to calculate vulnerability severity are available online while some are not available to the general public. The Common Vulnerability Scoring System (CVSS) is an open standard for scoring vulnerabilities. It was introduced by the Forum of Incident and Response Teams (FIRST) in 2005. CVSS evaluates the characteristics of a vulnerability and rates it on a scale of 0 to 10 using a predefined formula (Complete CVSS v1 Guide, 2022; Mell et al., 2007). The methodology and formulae to calculate CVSS base scores are explained in the Section 3.

VRSS and WIVSS are also publicly available systems to score vulnerabilities. Both use the same six metrics as CVSS to find the base score on a scale of 10. VRSS combines both quantitative and qualitative methodologies to produce a score and classifies vulnerabilities into three severity classes i.e., high, medium and low (Liu and Zhang, 2011). An improvement to VRSS using AHP (analytic hierarchy process) was introduced in (Liu et al., 2012). The authors introduced a new metric *Vulnerability Type Factor*, which depends on the historical evidence of severity of a vulnerability type. Using AHP and the new metric they were able to achieve better diversity among scores. Unlike CVSS and VRSS, WIVSS considers different weights for the Impact metrics, and generates more diverse scores. The authors further optimized the Impact weights by trying 14 different combinations following the same order of importance as above and some pre-specified rules (Spanos and Angelis, 2015). The scores generated using WIVSS show better accuracy and diversity than CVSS. Also, the qualitative rating distribution based on CVSS criteria is more balanced in WIVSS (Spanos et al., 2013). VRSS and WIVSS are further explained in Section 3 in detail.

Authors in (Sharma and Singh, 2018) developed a hybrid technique based on CVSS and VRSS. They included two more metrics in score calculation namely, Vulnerability Index and Remediation Level. Vulnerability Index captures the rate at which a particular vulnerability type is encountered over the years and Remediation Level is a time-based attribute and captures the preparation level of an organization against a vulnerability. Bugcrowd's VRT (Vulnerability Rating Taxonomy) (Bugcrowd's Vulnerability Rating Taxonomy - Bugcrowd 2022) is an open-source standard which classifies the vulnerabilities into 5 severity classes from P1 to P5, P1 being the most critical and P5 being the least critical. It is powered by crowdsourcing i.e., a large number of researchers and bug hunters around the globe are involved in vulnerability disclosures. In addition to being a simple system which quickly identifies the severity without complex calculations, VRT is also mapped to the industry standard CVSS in case a score is required.

Among other attributes, vulnerability type and vulnerability description are also available on NVD. Authors in (Wang et al., 2012) used attributes like vulnerability type, discovery period and CVSS severity score to measure and rank vulnerabilities for a particular software in case it is targeted by multiple attacks. The authors in (Sibal et al., 2017) used MCDM (Multi Criteria Decision Making) techniques to prioritize vulnerabilities based on its type. They used three techniques namely; NCD (Normalized Criteria Distance) (Pham and Pham, 2013), AHP (Analytic Hierarchy Process) (Saaty, 1990) and DEMATEL (Decision-Making Trial and Evaluation Laboratory) (Gabus and Fontela, 1972). The authors observed significant differences in the results when they considered the vulnerability types to be dependent on each other in DEMATEL technique from when they were considered independent of each other in NCD and AHP techniques. They suggested that interdependence must be taken into account while prioritizing for better results and optimization of the remediation process.

Although CVSS is considered as industry standard for scoring vulnerabilities, some critics of CVSS have highlighted the element of human emotion in the scoring process and the constant numbers in the formulas. Authors in (Fall and Kadobayashi, 2019), have captured the inability of CVSS to identify some of the most devastating and popular vulnerabilities, a.k.a. rockstar vulnerabilities, throughout history. They have also pointed out the human bias in some cases where vulnerabilities, which have already been exploited in the wild before their discovery, are deliberately scored higher in hindsight. Authors in (Sharma et al., 2021; Fröhwrth and Männistö, 2009; Han et al., 2017) try to deal with human bias by, try to deal with human bias by using vulnerability description to prioritize vulnerabilities. The process is to extract important keywords from the description and then apply various machine learn-

ing techniques to evaluate the severity of a vulnerability. This technique proves useful in the cases where an estimate of the severity of vulnerability is required as soon as it is identified even before the base metrics are assigned values. This addresses the problem of human bias which is created by the time delays between a CVE publication and assignment of its corresponding CVSS information (Ruohonen, 2019).

Authors in (Jung et al., 2022), highlighted the lack of capturing temporal characteristics of vulnerabilities and introduced a context-aware vulnerability prioritization (CAVP) model. Their model includes a Context Aware Vulnerability Scoring System (CAVSS) which automatically derives temporal metric values of vulnerabilities using a set of expert-validated heuristic rules. In (Zeng et al., 2021), authors have proposed a vulnerability prioritization system, called LICALITY, which calculates risk by capturing Likelihood and Criticality of exploitation of a vulnerability. They have used an AI approach by integrating neural networks with logic and probability in their NN-PLP (neural network-probabilistic logic programming) model which learns threat attributes from characteristics of previously exploited vulnerabilities.

Our proposed technique, VIEWSS, is a hybrid vulnerability scoring technique based on CVSS, VRSS and WIVSS. Unlike the basis techniques, our proposal assigns a qualitative rating to both Impact and Exploitability scores and varies the ratio of Impact and Exploitability score towards calculation of base severity score of a vulnerability accordingly. Our approach fortifies the vulnerability base severity score by giving a higher weightage to the more severe aspect out of Impact and Exploitability.

3. Overview of three popular vulnerability scoring techniques

In this section we discuss three popular scoring techniques: CVSS, VRSS and WIVSS. These techniques form the basis of our proposed scoring system. We have selected these techniques as basis for our proposed system because these techniques use a common set of metrics to calculate Impact and Exploitability scores. These metrics are related to the difficulty of exploiting a vulnerability and its impact on confidentiality, integrity and availability of a system. The values of these metrics have been assigned by NVD analysts and are available for all vulnerabilities reported on NVD. Final base score in all three is calculated by adding Impact and Exploitability score. Further, the range of scores generated by these techniques is same i.e. [0,10].

3.1. CVSS

CVSS is considered as the industry standard for determining the severity of vulnerabilities. There are three major versions of CVSS namely, v1, v2 and v3. Version 2 is most widely accepted and a large number of vulnerabilities are rated using it. Although the latest iteration is v3 and newly reported vulnerabilities are being scored only using v3. We will discuss v2 in detail as it is the most widely used, in terms of number of vulnerabilities scored, out of all the three versions of the scoring system and its base metrics are used in many scoring techniques including the VRSS and WIVSS, which forms the basis for our proposed technique.

Version 2 was released in 2007 and was widely adopted worldwide. CVSS contains three metric groups namely, Base, Temporal and Environmental. We will focus our attention only to the Base Metric Group as it captures the intrinsic qualities of a vulnerability that are constant over time and are unvaryingly applicable to different user environments. The metrics in this group are further divided into two sets. The first set consists of Access Vector, Access Complexity and Authentication. These capture how difficult or easy it is for an attacker to access a vulnerability for exploitation. The easier it is to access a vulnerability, the more its score will be and

Table 1
Base metric values and weights for CVSS V2 (Mell et al., 2007).

Metric Name	Values	Weights
Access Vector	Local, Adjacent Network, Network	0.395, 0.646, 1
Access Complexity	High, Medium, Low	0.35, 0.61, 0.71
Authentication	Multiple, Single, None	0.45, 0.56, 0.704
Confidentiality Impact(C)	None, Partial, Complete	0.0, 0.275, 0.660
Integrity Impact(I)	None, Partial, Complete	0.0, 0.275, 0.660
Availability Impact(A)	None, Partial, Complete	0.0, 0.275, 0.660

hence more severe. The second set consists of three impact metrics (C, I, A) which reflects how much damage a vulnerability can cause to the system if it is exploited successfully.

Table 1 shows the weights for each value of these metrics. Description for these metrics and the formula to calculate score are available at (Mell et al., 2007).

Formulas to calculate Base Score are:

$$\text{Impact Score} = 10.41 * (1 - (1 - C) * (1 - I) * (1 - A)) \quad (1)$$

$$\text{Exploitability Score} = 20 * \text{Access Vector} * \text{Access Complexity} * \text{Authentication} \quad (2)$$

$$\text{Base Score} = \text{Round}(((0.6 * \text{Impact}) + (0.4 * \text{Exploitability}) - 1.5) * f(\text{Impact}), 1) \quad (3)$$

where,

$$f(\text{Impact}) = 0 \text{ if Impact score} = 0 \text{ and } f(\text{Impact}) = 1.176 \text{ otherwise}$$

3.2. VRSS

Vulnerability Rating and Scoring System (VRSS) uses a qualitative rating and a quantitative score for scoring vulnerabilities. It uses the same six metrics as used in CVSS v2 base group to calculate a score. The authors assigned a qualitative rating based on the three impact metrics: Confidentiality Impact, Integrity Impact and Availability Impact. As each of these three metrics can be assigned three different values (none, partial and complete), there are 27 possible cases.

The vulnerability is first qualitatively classified into three levels namely, high, medium and low based on the impact score ranging from 6–9, 2–5 and 0–1 respectively. The impact score is assigned based on different combinations of impact on CIA properties. For example, when each of the C, I, A has Complete loss, an impact score of 9 is assigned and an impact score of 0 is assigned when each of C,I,A has None loss. The mapping for all the 27 possible cases to impact scores can be found at (Liu and Zhang, 2011). An Exploitability Score ranging from 0 to 1 is generated using the exploitability metrics; Access Vector, Access Complexity and Authentication. The formula for Exploitability Score is similar to that of CVSS and given in Eq. (4). Weights of these metrics are the same as in CVSS v2. Final score ranging from 0–10 is produced by adding Impact Score and Exploitability Score as given in Eq. (5).

$$\text{Exploitability Score} = 2 * \text{Access Vector} * \text{Access Complexity} * \text{Authentication} \quad (4)$$

$$\text{Base Score} = \text{Exploitability Score} + \text{Impact Score} \quad (5)$$

3.3. WIVSS

WIVSS (Weighted Impact Vulnerability Scoring System), introduced in 2013, is another scoring system which uses the same six metrics (Access Vector, Access Complexity, Authentication, Confidentiality Impact, Integrity Impact and Availability Impact) as used by CVSS version 2 to compute the base score but it considers different weights for CIA impact metrics in contrast to CVSS which uses the same weights for impact metrics (refer Table 1).

This disparity in weights for CIA impact metrics arises from the different impacts of loss of Confidentiality, Integrity and Availability on a system. Studies have shown that the impact of Integrity loss is more severe than Availability loss because a violation of integrity affects Availability impact and it is more difficult to notice. Moreover, the impact of Confidentiality loss is more severe than Integrity and Availability loss because it is hardest to detect and mostly remains unnoticed until the stolen data is published by the attacker (Mell and Scarfone, 2007; WANG, 2012).

Therefore, to achieve better accuracy and diversity of scores, different weights (shown in Table 2) were assigned to the three impact metrics. Weights assigned have the following order of importance: Confidentiality Impact > Integrity Impact > Availability Impact

Following is the formula to calculate WIVSS score (Spanos et al., 2013):

$$\text{WIVSS Score} = \text{Round}(\text{Exploitability Score} + \text{Impact Score} * f(\text{Impact})) \quad (6)$$

where,

$$\text{Impact Score} = C \text{ Impact} + I \text{ Impact} + A \text{ Impact}$$

$$\text{Exploitability Score} = 6 * \text{Access Vector} * \text{Access Complexity} * \text{Authentication}$$

$$f(\text{Impact}) = 0 \text{ if Impact} = 0$$

$$f(\text{Impact}) = 1 \text{ otherwise}$$

Table 2
Weights of impact metrics in WIVSS methodology.

Metric Name	Values	Weights (Spanos et al., 2013)	Optimized Weights (Security Update Guide - Microsoft 2022)
Confidentiality Impact	None, Partial, Complete	0.0, 1.5, 3.0	0.0, 1.8, 3.6
Integrity Impact	None, Partial, Complete	0.0, 1.2, 2.4	0.0, 1.1, 2.2
Availability Impact	None, Partial, Complete	0.0, 0.8, 1.6	0.0, 0.6, 1.2

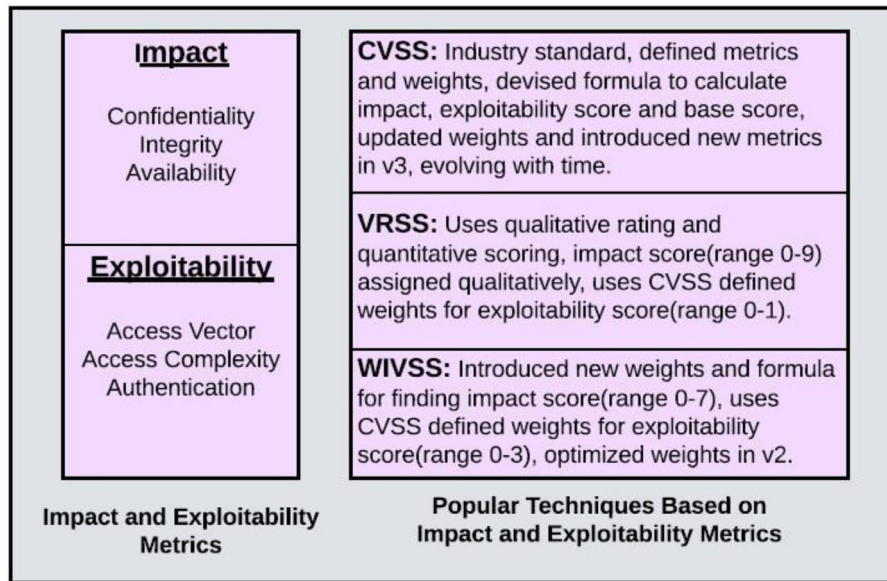


Fig. 2. An overview of popular vulnerability metrics and scoring techniques.

Table 3
Scores for hypothetical vulnerabilities (A, B and C).

Vulnerability Details	CVSS	VRSS	WIVSS
A (Impact: Maximum i.e. [C:C/I:C/A:C]; Exploitability: Lowest)	5.9	9.1	7.4
B (Impact: High i.e. [C:C/I:C/A:P]; Exploitability: Highest)	9.7	9	9.4
C (Impact: Medium i.e. [C:P/I:P/A:P]; Exploitability: Medium)	4.9	3.4	4.8

3.4. Comparison of CVSS, VRSS and WIVSS

In this section, a comparison of the three techniques is done in detail. A brief overview is shown in Fig. 2. The base scores in these three techniques are calculated using the same two sets of metrics i.e., Exploitability and Impact. The score is generated by adding the exploitability and impact scores. The weights for these metrics used by VRSS are the same as CVSS whereas WIVSS uses the same weights as CVSS for exploitability metrics and introduces its own optimized set of weights for impact metrics. Despite being similar in terms of formulas and metrics, there is a huge difference in scores of these techniques. This difference in scores arises from using different approaches to calculate the score. VRSS uses an impact dominant strategy to calculate the scores. The scores generated using VRSS are highly biased towards the impact metrics. In VRSS, while the impact score can take values in the range 0–9, exploitability score only ranges from 0 to 1.

To compare scores generated by these techniques, we generate scores for three hypothetical vulnerabilities having contrasting characteristics. Following are three hypothetical vulnerabilities:

- Impact is Maximum i.e., Confidentiality Impact: *Complete*, Integrity Impact: *Complete*, Availability Impact: *Complete*.
- Exploitability is Minimum i.e., Access Vector: *Local*, Complexity: *High*, Authentication: *Multiple*.
- Impact is High i.e., Confidentiality Impact: *Complete*, Integrity Impact: *Complete*, Availability Impact: *Medium*.
- Exploitability is Maximum i.e., Access Vector: *Network*, Complexity: *Low*, Authentication: *None*.
- Impact is Medium i.e., Confidentiality Impact: *Partial*, Integrity Impact: *Partial*, Availability Impact: *Partial*.
- Exploitability is Medium i.e., Access Vector: *Adjacent Network*, Complexity: *Medium*, Authentication: *Single*.

Scores generated by CVSS, VRSS and WIVSS for the above vulnerabilities A, B and C are shown in Table 3.

We observe that score of 'A' using VRSS will always be greater than that of 'B', irrespective of the difficulty level of exploitation of these two vulnerabilities. 'A' is scored at 9.12 ($9 + 0.12$) with lowest exploitability (hardest to exploit) and 'B' is scored at 9 ($8 + 1$) with highest exploitability (easiest to exploit). The hypothetical vulnerabilities 'A' and 'B' are scored at 5.9 and 9.7 using CVSS and at 7.4 and 9.4 using WIVSS. C with its medium exploitability and impact is scored at 4.9, 3.4 and 4.8 using CVSS, VRSS and WIVSS respectively.

Another significant difference is the weightage of the respective shares of Impact and Exploitability scores towards the final score, which is 7:3 in WIVSS, which is different than VRSS's 9:1 and CVSS's 6:4 (approx.) (Fig. 3). This clearly shows that VRSS scores are biased towards impact score. The score analysis and distribution are explained in more detail in Section 5.

Since, we know that only 2% of vulnerabilities are exploited successfully, exploitability plays an important role in calculating the correct score of a vulnerability. While CVSS gives due importance to exploitability and adjusts the score accordingly, impact severity is lost in this process. For example, hypothetical vulnerability 'A' is having the highest impact (complete loss of CIA) on the system but due to its low exploitability the overall score is adjusted and it is scored at 5.9 by CVSS v2. However, there is a low probability of exploitation of 'A', if it is exploited, the implications can be disastrous for the concerned organization.

In Section 3, we have explained and compared three popular vulnerability scoring techniques. All these techniques use same set of metrics to calculate score. VRSS's hybrid technique of using both qualitative and quantitative method to generate score is effective in identifying only impact dominant vulnerabilities and can be improved further. WIVSS's optimized weights for impact metrics and gives more importance to confidentiality than integrity and avail-

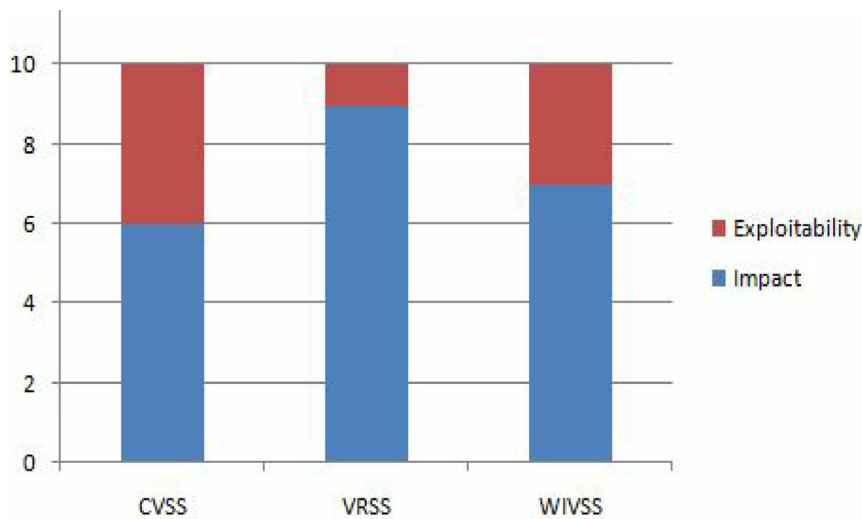


Fig. 3. Graph showing weightage of Exploitability and Impact in CVSS, VRSS and WIVSS scores.

ability. Fixed weightage of Impact and Exploitability can be considered as a limitation of these techniques. Therefore, a new technique which combines the effective features of these techniques and overcomes the aforementioned limitation is proposed in the next section.

4. Proposed scoring system: VIEWSS

In this section we discuss our proposed technique, VIEWSS, for scoring vulnerabilities for prioritization of software vulnerabilities in detail. It is a hybrid technique which combines the respective advantages of CVSS, VRSS and WIVSS. We have used the idea of using the *Impact Score* and *Rating Table* from VRSS with some significant changes. While assigning scores to possible impact metric values, we have considered the order of importance of C, I, A impact as followed by the authors in WIVSS. The Impact Scores and Qualitative Rating for all 27 possible combinations of impact metrics are given in Table 4.

Formula given in Eq. (2) is used to calculate Exploitability score out of 10. We have further assigned a qualitative rating of High, Medium and Low to exploitability for the score ranges as shown in

Table 5. This classification is done by equally dividing the possible 27 exploitability scores into three classes.

In our proposed technique, we have used a variable *Impact:Exploitability* weightage for calculating the base scores. This weightage depends on the qualitative rating of Exploitability and Impact. Whichever of the Impact and Exploitability is more severe, the same is given more weightage in the final base score to better reflect the severity of the vulnerability. If Impact and Exploitability have similar rating then equal weightage is given. This results in different base score formulas for three different types of vulnerabilities i.e., Impact dominant, Exploitability dominant and Equal Impact-Exploitability. Furthermore, this overcomes the limitation of fixed Impact:Exploitability weightage present in CVSS, VRSS and WIVSS. A flowchart showing the process of calculation of base scores is shown in Fig. 4.

To find the score for a vulnerability, firstly, we determine the *Impact* score and qualitative rating corresponding to the C, I and A impact metric values from Table 4. Secondly, the *Exploitability* score is calculated using Eq. (2) and its corresponding qualitative rating is determined from Table 5. Unlike the aforementioned techniques where *Impact:Exploitability* weightage was fixed as shown in Fig. 3, we have made the *Impact:Exploitability* ratio variable to calculate

Table 4
Impact rating and impact score based on all possible impact metric combinations.

Loss values of C,I,A	No. of Cases	Possible Impact metric values	Impact Scores	Impact Rating
Each of C,I,A has "Complete(C)" Loss	1	[C:C/I:C/A:C]	10	High
Confidentiality: C; Integrity: C; Availability: P/N	2	[C:C/I:C/A:P] [C:C/I:C/A:N]	9.8/9.5	High
Confidentiality: C; Integrity: P; Availability: C/P/N	3	[C:C/I:P/A:C] [C:C/I:P/A:P] [C:C/I:P/A:N]	9.2/8.8/8.4	High
Confidentiality: C; Integrity: N; Availability: C/P/N	3	[C:C/I:N/A:C] [C:C/I:N/A:P] [C:C/I:N/A:N]	8/7.6/7.2	High
Confidentiality: P; Integrity: C; Availability: C/P/N	3	[C:P/I:C/A:C] [C:P/I:C/A:P] [C:P/I:C/A:N]	6.8/6.4/6	High
Confidentiality: P; Integrity: P; Availability: C/P/N	3	[C:P/I:P/A:C] [C:P/I:P/A:P] [C:P/I:P/A:N]	5.6/5.2/4.8	Medium
Confidentiality: P; Integrity: N; Availability: C/P/N	3	[C:P/I:N/A:C] [C:P/I:N/A:P] [C:P/I:N/A:N]	4.4/4/3.6	Medium
Confidentiality: N; Integrity: C; Availability: C/P/N	3	[C:N/I:C/A:C] [C:N/I:C/A:P] [C:N/I:C/A:N]	3.2/2.8/2.4	Medium
Confidentiality: N; Integrity: P; Availability: C/P/N	3	[C:N/I:P/A:C] [C:N/I:P/A:P] [C:N/I:P/A:N]	2/1.6/1.2	Low
Confidentiality: N; Integrity: N; Availability: C/P	2	[C:N/I:N/A:C] [C:N/I:N/A:P]	0.8/0.4	Low
Each of C,I,A has "None(N)" Loss	1	[C:N/I:N/A:N]	0	Low

Table 5
Qualitative rating for exploitability score.

Exploitability Score Range	Possible Values	Qualitative Rating
5.14–10	[5.14, 5.49, 5.54, 6.39, 6.46, 6.83, 7.95, 8.59, 9.99]	High
3.15–4.93	[3.15, 3.18, 3.39, 3.55, 3.92, 3.95, 4.13, 4.41, 4.93]	Medium
1.24–3.14	[1.24, 1.55, 1.94, 2.03, 2.17, 2.52, 2.53, 2.69, 3.14]	Low

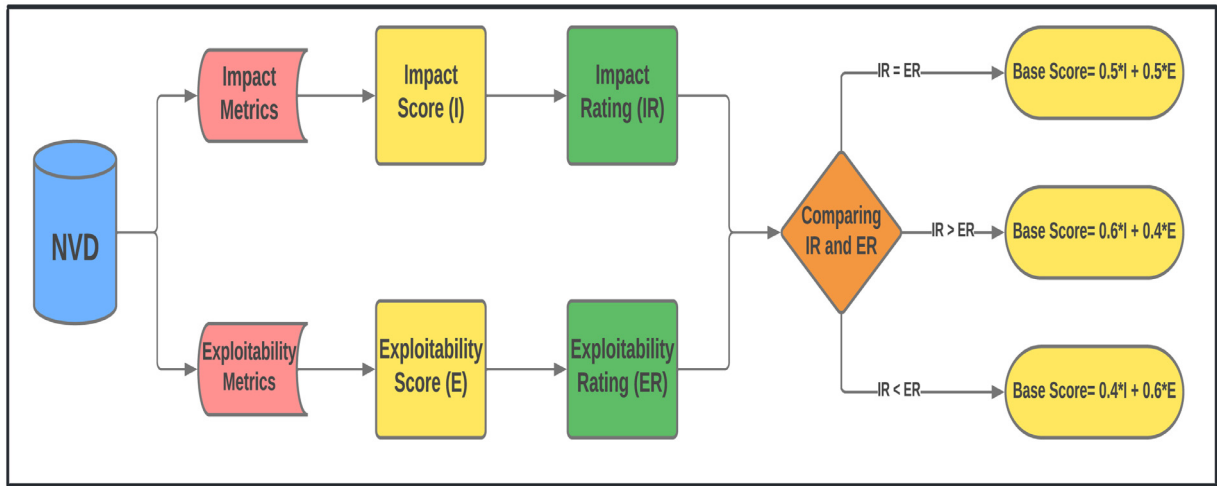


Fig. 4. Flowchart for our proposed technique VIEWSS.

our score. Its value depends on the difference in qualitative rating of the Impact and Exploitability scores.

Following are the rules to determine *Impact:Exploitability* in final base score:

- If the qualitative ratings of Exploitability and Impact are same, equal weightage is given to Exploitability and Impact i.e. *Impact:Exploitability* is set as 5:5.
- If the qualitative rating of Exploitability is greater than that of Impact, Exploitability is given more weightage i.e. *Impact:Exploitability* is set as 4:6.
- If the qualitative rating of Impact is greater than that of Exploitability, Impact is given more weightage i.e. *Impact:Exploitability* is set as 6:4.

The algorithm to compute score is as follows:

VIEWSS-BASESCORE (I, E, IR, ER)

```

if ((IR=H) and (ER=M)) or ((IR=M) and (ER=L)) or ((IR=H) and (ER=L))
  Score = 0.6*I + 0.4*E /*More weightage to Impact*/
else if ((IR=M) and (ER=H)) or ((IR=L) and (ER=M)) or ((IR=L) and (ER=H))
  Score = 0.4*I + 0.6*E /*More weightage to Exploitability*/
else
  Score = 0.5*I + 0.5*E /*Equal weightage*/
  
```

IR = Impact Rating; ER = Exploitability Rating; I = Impact Score;
E = Exploitability Score

5. Case studies

In this section we discuss some popular vulnerabilities and explain the usage of our scoring system. We describe the steps used to calculate a score for these vulnerabilities using our technique and compare our scores with those of the above discussed techniques.

5.1. Case study 1: specter (CVE ID: 2017–5753)

specter is a popular vulnerability which affected microprocessors from Intel, AMD and ARM used in billions of devices. Its description on NVD is given as, “Systems with microprocessors utilizing speculative execution and branch prediction may allow unauthorised disclosure of information to an attacker with local user access via a side-channel analysis”. The Base Metric Values are Access Vector: Local, Access Complexity: Medium, Authentication: None, Confidentiality Impact: Complete, Integrity Impact: None, Availability Impact: None (NVD - CVE-2017-5753, 2022).

Following are the steps to find the score of the specter using our technique:

- Find out the impact score and rating using Table 4. Impact score is 7.2 with *High* rating.
- Calculate the exploitability score using Eq. (2) and weights for metrics in Table 1. We get the Exploitability score: $20 \times 0.395 \times 0.61 \times 0.704 = 3.39$.
- Find out the qualitative rating for exploitability score from Table 5. Rating for 3.39 is *Medium*.
- Compare Impact rating and Exploitability rating. Impact rating is *High* and Exploitability rating is *Medium*, referring to flowchart in Fig. 4 or the algorithm in previous section, Base Score can be calculated using the formula $0.6 \times \text{Impact score} + 0.4 \times \text{Exploitability score}$.
- Base score using our technique is 5.7 for specter vulnerability.

CVSS v2 base score is 4.7, CVSS v3 base score is 5.6, VRSS score is 4.3, WIVSS v1 score is 4.0 and WIVSS v2 is 4.6 for specter vulnerability.

5.2. Case study 2: double kill (CVE ID: 2018–8174)

Double Kill (ZDNet, 2022) is a Windows VBScript engine vulnerability which allows remote code execution on different products of Microsoft including Windows 7, Windows 8.1 and Windows 10. It was among the top exploited Microsoft vulnerabilities in 2019. The Base Metric Values are Access Vector: Network, Access Complexity: High, Authentication: None, Confidentiality Impact: Complete, Integrity Impact: Complete, Availability Impact: Complete (NVD - CVE-2018-8174, 2022). CVSS v2 base score is 7.6, VRSS score is 9.5 and WIVSS score is 8.5. Using the same steps as in Case Study 1, the base score from our technique is 8.0.

For both of these popular vulnerabilities our technique generates a higher score than CVSS. VRSS and WIVSS being impact dominant generates higher scores for Double Kill vulnerability as it results in complete loss of Confidentiality, Integrity and Availability. For specter, which results in complete confidentiality loss, the score generated by our technique is highest among all other, as we give more weight to confidentiality than integrity and availability when calculating the impact score.

6. Experiment and results

In this section we have applied our technique on large datasets of vulnerabilities and generated scores for these using CVSS V2,

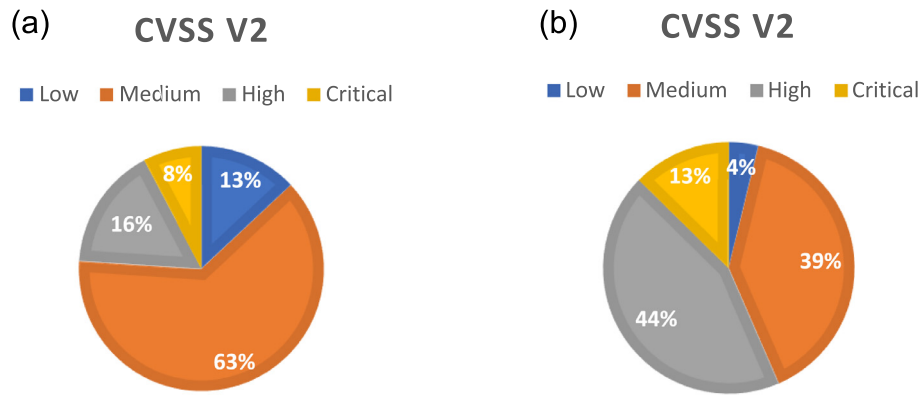


Fig. 5. (a): Qualitative Ratings (Dataset 1) (b): Qualitative Ratings (Dataset 2).

Table 6
From scores to qualitative rating.

Score range	Rating
9–10	Critical
7–8.9	High
4–6.9	Medium
0–3.9	Low

CVSS V3, VRSS, WIVSS V1 and WIVSS V2. We have used two datasets, first one contains vulnerabilities reported in last five years and second one contains 'high-risk' vulnerabilities. These two datasets are further described in Section 6.1. We analyze the scores generated for these two datasets and compare the discussed techniques in Sections 6.2 and 6.3.

6.1. Dataset description

Dataset 1:

First dataset contains around 90,000 vulnerabilities. We extracted all vulnerabilities published on NVD from 2017 to 2022. Out of these 90,000 vulnerabilities, 83,595 were assigned base metric values by NVD analysts. A qualitative rating distribution for Dataset 1 as per CVSS v2 is shown in Fig. 5(a). We have used this dataset to analyze and compare the scores generated by the discussed techniques.

Dataset 2:

Second dataset contains 12,243 vulnerabilities cross-referenced from NVD and Exploit-DB. We refer to the second dataset as High-risk dataset as these vulnerabilities have public exploit information available as reported by Exploit-DB. It can be seen from Fig. 5(b), that 96% of vulnerabilities in Dataset 2 are lying in Critical, High or Medium severity classes. This dataset is used to analyze the performance of discussed techniques in terms of identifying the threat posed by high-risk vulnerabilities.

6.2. Analysis of scores in dataset 1

To compare the severity scores computed by our proposed technique with the existing techniques, we calculated scores for all 83,595 vulnerabilities in Dataset 1. We applied the formula given in Section 4.1 to calculate VRSS and WIVSS scores of these vulnerabilities and extracted the CVSS V2 and V3 base score from the vulnerability details provided on NVD. We also mapped the scores to a qualitative rating as per CVSS V3 standard for all the techniques as shown in Table 6.

Pie Charts in Fig. 6 show the distribution of qualitative ratings of the techniques for Dataset 1.

We can see from the above graphs that the majority of vulnerabilities are lying in "Medium" and "Low" severity rating classes in WIVSS and VRSS. Whereas in CVSS and our technique, the majority of vulnerabilities are falling in "High" and "Medium" severity rating classes. We also notice the high number of vulnerabilities in "Low" severity class for VRSS. In Table 7 we have summarized some important parameters of scores produced by all the techniques for these vulnerabilities.

The statistical metrics in Table 7 and their significance is discussed as follows:

- Score Range:** It shows the range of scores generated by the techniques. All the techniques scores vulnerabilities on a scale of 10. The minimum score in the *Score Range*, is nearly similar for all techniques except CVSS V3 which stands out with a higher minimum score of 1.8.
- Mean:** Mean gives the average value of all the scores. It is a clear indicator of the magnitude of scores generated by these techniques. It ranges from 3.66 (VRSS) to 7.19 (CVSS V3). It is evident from Fig. 6 that majority of VRSS scores are low with a mean value of 3.66 and those of V3 are high with mean value of 7.19. Mean value for the other techniques lies in medium score range as per Table 6. Mean score for our proposed technique, VIEWSS, is 6.45 and lies in between CVSS V2 and V3.
- Standard Deviation:** It is a measure of dispersion/variability which shows how spread out the scores are (Walpole, 1985). Low value indicates that the data are clustered around the mean and high indicates that the data are more spread out. All the above techniques generates scores with comparable standard deviations from the mean, except Click or tap here to enter text.VRSS, which gives much higher standard deviation than the other techniques.
- Skewness:** It indicates the measure of asymmetry in a distribution. Normal distributions have zero skewness. A positive value indicates that the majority of values lie to the left of the mean. While, a negative skew value indicates that the majority of values are present to the right of the mean (Kim, 2013). Skewness of score distribution generated through our technique is -0.13 and is more consistent with normal distribution as compared with other techniques. VRSS's score distribution shows substantial non-normality with highest skewness.
- Kurtosis:** It is a measure of relative peakedness or flatness of a distribution compared with normal distribution. A positive Kurtosis value shows that the distribution has heavy tails i.e., there are more samples in tails as compared to a normal distribution and hence more outliers whereas negative value indicates lighter tails i.e., lesser outliers (Kim, 2013). Highest value of Kurtosis is observed for VRSS, and it can also be seen from Fig. 7 that VRSS scores are more concentrated in the tails. With

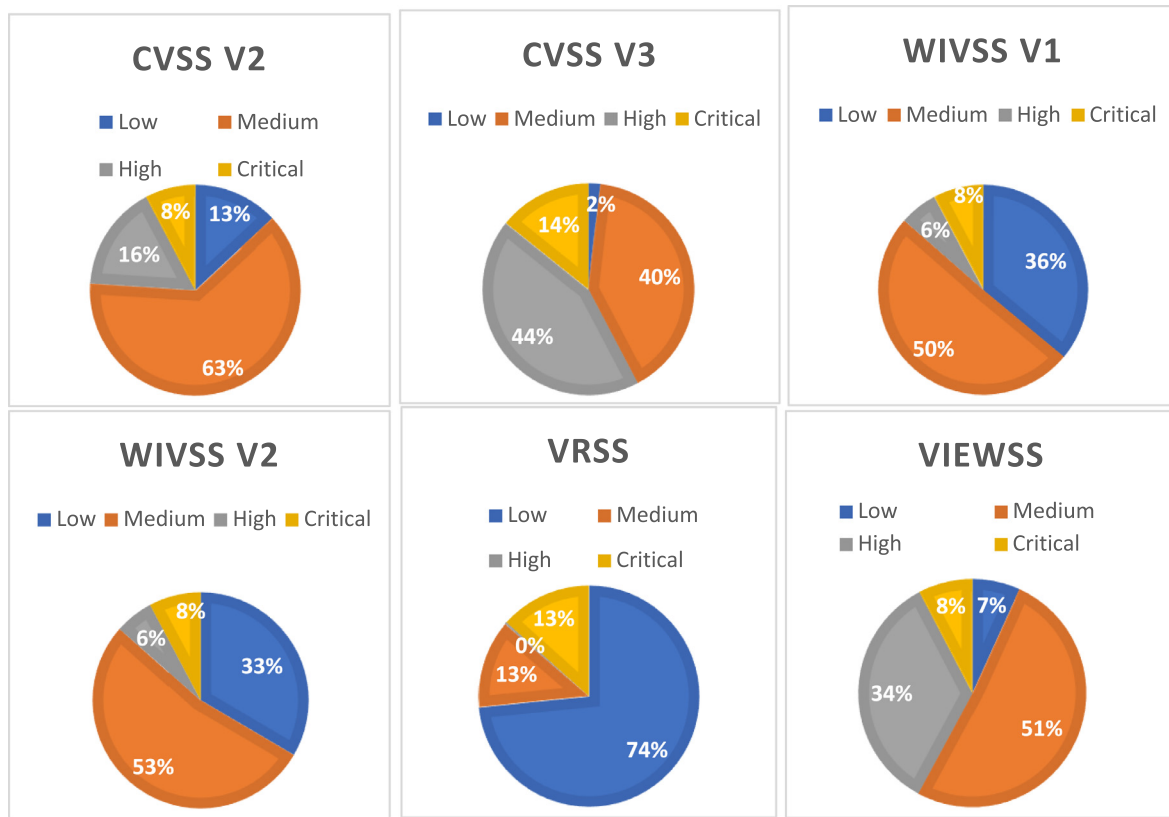


Fig. 6. Pie Charts of Qualitative Rating of vulns in Dataset 1 for CVSS V2, CVSS V3, WIVSS, WIVSS V2 VRSS and VIEWSS.

Table 7

Analysis of scores generated by VRSS, WIVSS and CVSS and our proposed technique.

Technique	Score Range	Mean	Standard Deviation	Skewness	Kurtosis	Distinct
VRSS	1.2 – 10	3.66	2.58	1.56	1.20	77
WIVSS v1	1.4 – 10	5.16	1.94	0.93	0.17	74
WIVSS v2	1.2 – 10	5.16	1.95	0.86	0.10	76
CVSS V2	1.0 – 10	5.60	1.86	0.34	−0.18	67
CVSS V3	1.8 – 10	7.19	1.64	−0.14	−0.64	80
VIEWSS*	1.2 – 10	6.45	1.59	−0.13	−0.37	79

a negative Kurtosis of -0.37 , distribution of scores generated through our technique has lighter tails as compared to a normal distribution. Scores generated by WIVSS V2 exhibits near normal Kurtosis with a value of 0.10 .

- Distinct:** It gives total number of distinct score values in the score range of a particular technique. Scores for all the techniques have been rounded off to one decimal place. For example, there are 91 possible distinct scores in the range 1.0 to 10.0 . A higher number of distinct scores indicates that the vulnerabilities are better differentiated from each other. CVSS V3 generates the greatest number of distinct scores i.e., 80 .

Graphs in Fig. 7 show the probability distribution function of scores generated by existing and the proposed technique for Dataset 1., it can be inferred from the distribution of scores in above graphs that VRSS scores are highly skewed to the right, while for other techniques these are less skewed if not symmetrical. The graph for VRSS in Fig. 7 shows that the high standard deviation of VRSS is not due to distinctiveness of scores. Instead, the scores in VRSS are more like each other and are clustered in either the very low or very high range and hence the vulnerabilities cannot be properly distinguished from each other in this technique.

6.3. Analysis of scores in dataset 2

We have also calculated scores for 12,243 high-risk vulnerabilities in Dataset 2. Out of these 12,243 vulns only 4748 were assigned CVSS V3 metrics. We mapped the scores to qualitative rating as per Table 6. The bar graph in Fig. 8, shows qualitative ratings distribution of vulnerabilities in Dataset 2. All techniques, except VRSS, identify the risk correctly by classifying the majority of these vulnerabilities in Critical, High or Medium severity class. It is observed that our technique performs best among these by putting more than 74% vulnerabilities in High and Critical severity class.

For this dataset we have assigned a baseline score of 6.0 , above which we consider the scored vulnerability to be accurately identified as a high-risk vulnerability by the discussed scoring techniques. However, the range of acceptable vulnerability score may vary across organizations as each software vendor has their own vulnerability prioritization and remediation standards. According to PCI DSS, the standard for security of credit card data, high risk vulnerabilities may include a vulnerability with CVSS score of 4.0 or above while CVSS based patching policy assigns highest priority to vulnerabilities with a CVSS score of 7.0 or higher (Allodi and Massacci, 2014) (Example of CVSS based Patching Policy 1.0 Overview, 2023). Authors in (Sharma et al., 2022) consid-

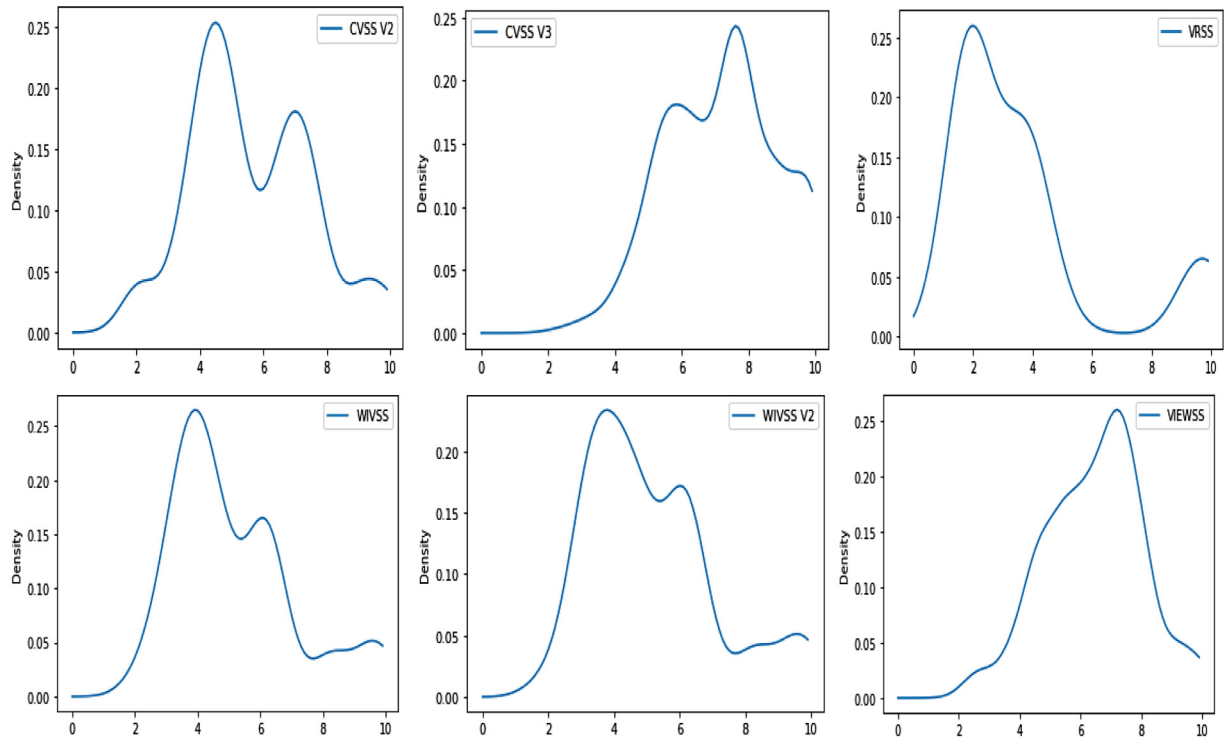


Fig. 7. Probability Density Function graphs of scores generated by CVSS V2 and V3, VRSS, WIVSS V1 and V2 and VIEWSS*.

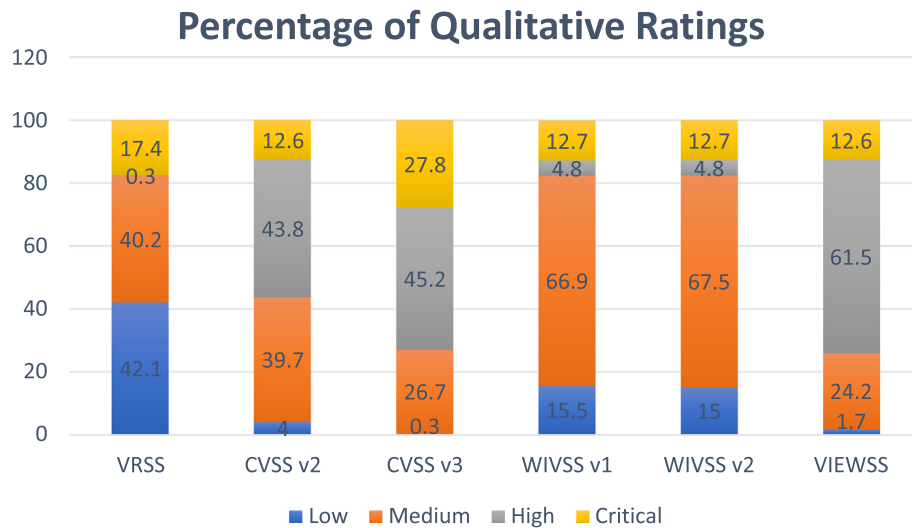


Fig. 8. Qualitative Ratings generated by all the techniques for Dataset 2.

ers vulnerabilities in High or Medium severity classes to be high-risk. We chose the score of 6.0 and above for a vulnerability to be qualified as high-risk, because it includes vulnerabilities in Critical, High and Upper-medium severity class as per the CVSS specifications. Table 8 summarizes the performance of discussed techniques in identifying the number of vulnerabilities above different scores i.e., 4, 6, 8 and 9.

It is observed from Table 8 that our proposed technique and CVSS V3 performs significantly better than all the techniques in identifying the risk accurately. We calculate accuracy by finding the percentage of vulnerabilities scored above the baseline score of 6.0 in Dataset 2. Our proposed technique was the second most accurate with 84.1% vulnerabilities scored above baseline. It is also observed that the proposed technique

performs best if the baseline score is set as 8.0. While VRSS scores only 17.7% vulnerabilities above baseline, the percentage of vulnerabilities scored above 9 in VRSS is just behind CVSS V3. This can be attributed to VRSS's impact dominant scoring methodology.

In Section 3.4, we compared scores generated by CVSS, VRSS and WIVSS for hypothetical vulnerabilities A, B and C (Table 3). Scores for the same vulnerabilities using our proposed technique are shown in Table 9.

It can be seen that using our technique, A is still in the medium severity range, attributed to its low exploitability, but the score is higher than CVSS as a result of due weightage given to its high impact. Vulnerability B, having high impact and exploitability, is scored at its highest using our technique and C, with its medium

Table 8

Performance analysis of all techniques for dataset 2.

Technique	Total no. of vulns	Percentage of Vulnerabilities			
		Score > 4	Score > 6 (Accuracy)	Score > 8	Score > 9
CVSS V2	12,243	11,639 (95.1)	8920 (72.9)	2146 (17.5)	1406 (11.5)
CVSS V3	4748	4731 (99.6)	4044 (85.2)	2134 (44.9)	1319 (27.8)
WIVSS v1	12,243	10,335 (84.4)	8183 (66.8)	2042 (16.7)	1536 (12.5)
WIVSS v2	12,243	10,406 (85)	8242 (67.3)	2124 (17.3)	1561 (12.7)
VRSS	12,243	2452 (20)	2172 (17.7)	2133 (17.4)	2132 (17.4)
VIEWSS*	12,243	12,038 (98.3)	10,299 (84.1)	6280 (51.3)	1402 (11.5)

Table 9

Scores generated by CVSS, VRSS, WIVSS and VIEWSS for hypothetical vulnerabilities.

Vulnerability Details	CVSS	VRSS	WIVSS	VIEWSS*
A (Impact: Maximum i.e. [C:C/I:C/A:C]; Exploitability: Lowest)	5.9	9.12	7.37	6.5
B (Impact: High i.e. [C:C/I:C/A:P]; Exploitability: Highest)	9.7	9	9.39	9.8
C (Impact: Medium i.e. [C:P/I:P/A:P]; Exploitability: Medium)	4.9	3.44	4.8	4.8

impact and exploitability, is given a lower medium range score of 4.8.

7. Conclusion and future work

In this paper, a novel hybrid scoring technique VIEWSS for prioritization of vulnerabilities is proposed and is also compared with three existing techniques for scoring vulnerabilities. It is observed that the existing scoring techniques discussed in this paper are giving more weightage to Impact of vulnerability than to its Exploitability. These techniques do not consider the difference between the magnitude of actual Impact and Exploitability of a vulnerability while scoring it. This may lead to the situation where a more severe vulnerability is given a lower base score and remain unnoticed by the security team.

On the other hand, hybrid technique VIEWSS proposed by us considers variable weightage for Impact and Exploitability scores for calculating the score for a vulnerability. We created two datasets by extracting vulnerabilities from NVD. Dataset 1 contained 83,595 vulnerabilities reported from 2017 to 2022. Dataset 2 contained 12,243 high-risk vulnerabilities cross-referenced from NVD and Exploit-DB. Scores for both the datasets were calculated using CVSS V2, CVSS V3, VRSS, WIVSS V1, WIVSS V2 and the proposed VIEWSS. The proposed technique, VIEWSS, showed promising results when compared with the discussed techniques in terms of score distribution and distinctiveness of scores on Dataset 1. We also performed analysis of performance using Dataset 2 containing high-risk vulnerabilities and found that our technique outperforms all the other discussed techniques, except CVSS V3 for which the dataset was not complete, in terms of identifying the risk accurately. We believe that our results demonstrate the vast potential of calculating the vulnerability base scores using a variable ratio of Impact and Exploitability in the base score formula and it will pave the way for researchers to explore this option in future vulnerability prioritization techniques.

In the future, discovery trends of different types of vulnerabilities and information from other vulnerability databases can be explored to improve the prioritization process. The formula to calculate base score can also be experimented with, by altering the impact exploitability ratio and weights of metrics, depending upon past information about exploitation of a particular type of vulnerability. Base score can also be augmented by using other characteristics of a vulnerability. The element of human emotion in assigning metric values for already exploited vulnerabilities can be dealt with by improving vulnerability classification using its description.

Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

CRediT authorship contribution statement

Abhishek Sharma: Conceptualization, Methodology, Data curation, Formal analysis, Writing – original draft. **Sangeeta Sabharwal:** Supervision, Writing – review & editing. **Sushama Nagpal:** Supervision, Writing – review & editing.

Data availability

Data will be made available on request.

Supplementary materials

Supplementary material associated with this article can be found, in the online version, at [doi:10.1016/j.cose.2023.103256](https://doi.org/10.1016/j.cose.2023.103256).

References

- "About Secunia Research | Flexera." <https://www.flexera.com/products/software-vulnerability-research/secunia-research> (accessed Mar. 08, 2022).
- Allodi, L., Massacci, F., 2014. Comparing vulnerability severity and exploits using case-control studies. *ACM Trans. Inf. Syst. Secur.* 17 (1), 1–20. doi:[10.1145/2630069](https://doi.org/10.1145/2630069).
- "API Vulnerabilities." <https://nvd.nist.gov/developers/vulnerabilities> (accessed Mar. 08, 2022).
- "Bugcrowd's Vulnerability Rating Taxonomy - Bugcrowd." <https://bugcrowd.com/vulnerability-rating-taxonomy> (accessed Mar. 09, 2022).
- "Complete CVSS v1 Guide." <https://www.first.org/cvss/v1/guide> (accessed Mar. 08, 2022).
- "Example of CVSS based Patching Policy 1.0 Overview"
- Fall, D., Kadoyoshi, Y., 2019. The common vulnerability scoring system vs. rock star vulnerabilities: why the discrepancy? In: Proceedings of the 5th International Conference on Information Systems Security and Privacy, pp. 405–411. doi:[10.5220/0007387704050411](https://doi.org/10.5220/0007387704050411).
- Frühwirth, C., Männistö, T., 2009. Improving CVSS-based vulnerability prioritization and response with context information. In: 2009 3rd International Symposium on Empirical Software Engineering and Measurement, ESEM 2009, pp. 535–544. doi:[10.1109/ESEM.2009.5314230](https://doi.org/10.1109/ESEM.2009.5314230).
- Gabus, A., Fontela, E. "World Problems, an Invitation to Further Thought within the Framework of DEMATEL," Battelle Geneva Research Center, Geneva, Switzerland, pp. 1–8, 1972.
- Han, Z., Li, X., Xing, Z., Liu, H., Feng, Z., 2017. Learning to predict severity of software vulnerability using only vulnerability description. In: Proceedings - 2017 IEEE International Conference on Software Maintenance and Evolution, ICSME 2017, pp. 125–136. doi:[10.1109/ICSME.2017.52](https://doi.org/10.1109/ICSME.2017.52).
- "IBM X-Force Security Services | IBM." <https://www.ibm.com/security/xforce> (accessed Mar. 08, 2022).

- Jung, B., Li, Y., Bechor, T., 2022. CAVP: a context-aware vulnerability prioritization model. *Comput. Secur.* 116, 102639. doi:[10.1016/j.cose.2022.102639](https://doi.org/10.1016/j.cose.2022.102639).
- Kenna Security "Prioritization to prediction volume 1: analyzing vulnerability remediation strategies | Kenna Security." <https://www.kennasecurity.com/resources/prioritization-to-prediction-report/> (accessed Mar. 08, 2022).
- Kim, H.-Y., 2013. Statistical notes for clinical researchers: assessing normal distribution (2) using skewness and kurtosis. *Restor. Dent. Endod.* 38 (1), 52–54. doi:[10.5395/RDE.2013.38.1.52](https://doi.org/10.5395/RDE.2013.38.1.52).
- Liu, Q., Zhang, Y., 2011. VRSS: a new system for rating and scoring vulnerabilities. *Comput. Commun.* 34 (3), 264–273. doi:[10.1016/j.comcom.2010.04.006](https://doi.org/10.1016/j.comcom.2010.04.006).
- Liu, Q., Zhang, Y., Kong, Y., Wu, Q., 2012. Improving VRSS-based vulnerability prioritization using analytic hierarchy process. *J. Syst. Softw.* 85 (8), 1699–1708. doi:[10.1016/j.jss.2012.03.057](https://doi.org/10.1016/j.jss.2012.03.057).
- Mell, P., Scarfone, K., 2007. Improving the common vulnerability scoring system. *IET Inf. Secur.* 1 (3), 119–127. doi:[10.1049/IET-IFS:20060055](https://doi.org/10.1049/IET-IFS:20060055).
- Mell, P., Scarfone, K., Romanosky, S., "A complete guide to the common vulnerability scoring system version 2.0," 2007.
- "Mozilla Foundation Security Advisories – Mozilla." <https://www.mozilla.org/en-US/security/advisories/> (accessed Mar. 08, 2022).
- "NVD - CVE-2017-5753." <https://nvd.nist.gov/vuln/detail/CVE-2017-5753> (accessed Mar. 09, 2022).
- "NVD - CVE-2018-8174." <https://nvd.nist.gov/vuln/detail/CVE-2018-8174> (accessed Mar. 30, 2022).
- "NVD - Data Feeds." <https://nvd.nist.gov/vuln/data-feeds> (accessed Mar. 08, 2022).
- Pham, H., Pham, H., 2013. Loglog fault-detection rate and testing coverage software reliability models subject to random environments. *Vietnam J. Comput. Sci.* 1 (1), 39–45. doi:[10.1007/S40595-013-0003-4](https://doi.org/10.1007/S40595-013-0003-4), 2013 1:1.
- Ruohonen, J., 2019. A look at the time delays in CVSS vulnerability scoring. *Appl. Comput. Inf.* 15 (2), 129–135. doi:[10.1016/J.ACI.2017.12.002](https://doi.org/10.1016/J.ACI.2017.12.002).
- Saaty, T.L., 1990. How to make a decision: the analytic hierarchy process. *Eur J Oper Res* 48 (1), 9–26. doi:[10.1016/0377-2217\(90\)90057-1](https://doi.org/10.1016/0377-2217(90)90057-1).
- "Security Update Guide - Microsoft." <https://msrc.microsoft.com/update-guide> (accessed Mar. 08, 2022).
- "Severity Guidelines for Security Issues." <https://www.chromium.org/developers/severity-guidelines/> (accessed Mar. 08, 2022).
- "Severity Ratings - Red Hat Customer Portal." <https://access.redhat.com/security/updates/classification> (accessed Mar. 08, 2022).
- Sharma, R., Singh, R.K., "An improved scoring system for software vulnerability prioritization," 2018, pp. 33–43. doi:[10.1007/978-981-10-5577-5_3](https://doi.org/10.1007/978-981-10-5577-5_3).
- Sharma, R., Sibal, R., Sabharwal, S., 2021. Software vulnerability prioritization using vulnerability description. *Int. J. Syst. Assur. Eng. Manag.* 12 (1), 58–64. doi:[10.1007/S13198-020-01021-7/TABLES/6](https://doi.org/10.1007/S13198-020-01021-7/TABLES/6).
- Sharma, A., Sabharwal, S., Nagpal, S., 2022. Performance analysis of quantitative software vulnerability prioritization techniques. In: *Smart Innovation, Systems and Technologies*, 303 SIST, pp. 161–171. doi:[10.1007/978-981-19-2719-5_15/COVER](https://doi.org/10.1007/978-981-19-2719-5_15/COVER).
- Shirey, R., "Internet security glossary, version 2," Aug. 2007, doi:[10.17487/RFC4949](https://doi.org/10.17487/RFC4949).
- Sibal, R., Sharma, R., Sabharwal, S., 2017. Prioritizing software vulnerability types using multi-criteria decision-making techniques. *Life Cycle Reliab. Saf. Eng.* 6 (1), 57–67. doi:[10.1007/s41872-017-0006-8](https://doi.org/10.1007/s41872-017-0006-8).
- Spanos, G., Angelis, L., "Impact metrics of security vulnerabilities: analysis and weighing vol. 24, no. 1–3, pp. 57–71, Jul. 2015, doi:[10.1080/19393555.2015.1051675](https://doi.org/10.1080/19393555.2015.1051675).
- Spanos, G., Sioziou, A., Angelis, L., 2013. WIVSS: a new methodology for scoring information systems vulnerabilities. In: *ACM International Conference Proceeding Series*, pp. 83–90. doi:[10.1145/2491845.2491871](https://doi.org/10.1145/2491845.2491871).
- "Symantec Security Center." <https://www.broadcom.com/support/security-center> (accessed Mar. 08, 2022).
- Walpole, M.R., 1985. *Probability and Statistics for Engineers and Scientists*. MacMillan, New York, NY.
- Wang, J.A., Guo, M., Wang, H., Zhou, L., 2012. Measuring and ranking attacks based on vulnerability analysis. *Inf. Syst. e-Bus. Manag.* 10 (4), 455–490. doi:[10.1007/S10257-011-0173-5/TABLES/11](https://doi.org/10.1007/S10257-011-0173-5/TABLES/11).
- Yang, Y., Wang, Y., 2012. PVL: a Novel metric for single vulnerability rating and its application in IMS. *J. Comput. Inf. Syst.* 8 (2), 579–590.
- ZDNet, 2022 "These are the top ten security vulnerabilities most exploited by hackers | ZDNet." <https://www.zdnet.com/article/these-are-the-top-ten-security-vulnerabilities-most-exploited-by-hackers-to-conduct-cyber-attacks/> (accessed Mar. 30, 2022).
- Zeng, Z., Yang, Z., Huang, D., Chung, C.J., 2021. LICALITY – likelihood and criticality: vulnerability risk prioritization through logical reasoning and deep learning. *IEEE Trans. Netw. Serv. Manag.* doi:[10.1109/TNSM.2021.3133811](https://doi.org/10.1109/TNSM.2021.3133811).

Abhishek Sharma: Working as a TRF (Teaching-cum-Research Fellow) at Netaji Subhas University of Technology. Acquired Masters of Technology (CSE) degree from GGSIU in 2018. Research areas include software vulnerability prioritization, classification and discovery modeling.

Sangeeta Sabharwal: Currently she is working as Professor in CSE dept at NSUT. She has done her B.E. and M.E. from Delhi College of Engineering and Ph.D from Delhi University. Her areas of interest are Requirement engineering, Meta modeling, object Oriented analysis, Software testing and Data Warehouse. She has published several papers in international journals and is on the editorial boards of national and international journals. She has also authored a book on Software Engineering. She is a Senior member of IEEE, ACM and Computer Society of India and is invited as expert countrywide. Several research scholars are currently pursuing their Ph.D. under her guidance.

Sushama Nagpal: Currently working as Professor in the Division of Computer Engineering at NSUT, New Delhi. She did her B.E. in Computer Science and Engineering from C. R. State College of Engineering, Murthal (Now DCRUST, Muthal). She obtained her M.Tech and Ph.D. degree from University of Delhi. She has almost 20 years of experience in teaching and research. Her areas of interests include Software Quality Measurement, Data Warehouse, Data Mining/Machine Learning, Social Network Analysis and Recommender Systems. She has published various research papers in reputed international journals and conferences. She has reviewed number of research articles for reputed international journals and acted as Member, Technical Program Committee for international conferences.